

Security+ 4.5 · Endpoint Security

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 4.5 — Endpoint Security (9:25)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Endpoint: EDR (behavior + isolate + revert — evolution do antivírus); posture assessment (cheça o dispositivo antes de dar acesso — MDM, AV, patch); remediation; NAC (802.1X + postura).

Highlights que a prova cobra

- EDR: vê o comportamento e RESPONDE (isola o host)
- Posture assessment: o 'exame de saúde' antes de conectar à rede

Dicas de prova & Cenários Típicos

- 'detects malicious behavior on endpoint and can isolate'=EDR

Cenário clássico de exame: 'endpoint detectou comportamento anômalo e isolou a máquina'=EDR.

Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 4.5 — Endpoint Security)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **DLP:** Data Loss Prevention: Ferramenta técnica que monitora, detecta e bloqueia a exfiltração não autorizada de dados sensíveis (CPF, cartões, propriedade intelectual) em repouso, trânsito ou uso.
- **EDR:** Endpoint Detection and Response: Ferramenta instalada em estações e servidores que monitora comportamentos suspeitos, detecta ameaças avançadas e permite isolamento e contenção remota imediata.

Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Evolução do antivírus que monitora e RESPONDE à ameaça direto no dispositivo é:

- A)** EDR
- B)** DLP
- C)** IDS de rede
- D)** Proxy

2. Cenário corporativo (Endpoint Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: 'EDR: vê o comportamento e RESPONDE (isola o host)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: EDR: vê o comportamento e RESPONDE (isola o host)...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

3. Cenário corporativo (Endpoint Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: 'Posture assessment: o 'exame de saúde' antes de conectar à rede'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Posture assessment: o 'exame de saúde' antes de conectar à rede...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (Endpoint Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: '"detects malicious behavior on endpoint and can isolate'=EDR'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'detects malicious behavior on endpoint and can isolate'=EDR...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Endpoint Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: "endpoint detectou comportamento anômalo e isolou a máquina"=EDR.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'endpoint detectou comportamento anômalo e isolou a máquina'=EDR....
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Endpoint Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: 'EDR: vê o comportamento e RESPONDE (isola o host)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: EDR: vê o comportamento e RESPONDE (isola o host)...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Endpoint Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: 'Posture assessment: o 'exame de saúde' antes de conectar à rede'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Posture assessment: o 'exame de saúde' antes de conectar à rede...

8. Cenário corporativo (Endpoint Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: "detects malicious behavior on endpoint and can isolate"=EDR'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'detects malicious behavior on endpoint and can isolate'=EDR...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Endpoint Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: "endpoint detectou comportamento anômalo e isolou a máquina"=EDR.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'endpoint detectou comportamento anômalo e isolou a máquina'=EDR....

10. Cenário corporativo (Endpoint Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: 'EDR: vê o comportamento e RESPONDE (isola o host)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: EDR: vê o comportamento e RESPONDE (isola o host)...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) A — EDR.

✓ **Por que está certa:** EDR (Endpoint Detection and Response) é a evolução dos antivírus tradicionais, combinando monitoramento contínuo, detecção comportamental e capacidades de resposta direta no endpoint. No CompTIA Security+ (SY0-701), o EDR é descrito como uma solução que não apenas detecta ameaças, mas também permite ações como isolar o dispositivo, encerrar processos maliciosos e reverter alterações. O enunciado descreve exatamente uma evolução do antivírus que monitora e responde à ameaça direto no dispositivo, o que corresponde ao EDR.

✗ **Por que as outras estão erradas:**

- *DLP:* DLP (Data Loss Prevention) é uma tecnologia focada em prevenir a exfiltração de dados sensíveis, monitorando e bloqueando transferências não autorizadas. Ela não é uma evolução do antivírus e não tem como função principal detectar e responder a malwares no endpoint. Portanto, não se aplica ao descrito.
- *IDS de rede:* IDS de rede (Network Intrusion Detection System) monitora o tráfego de rede em busca de atividades maliciosas, gerando alertas. Ele não atua diretamente no dispositivo para responder a ameaças, nem é uma evolução do antivírus. Sua função é passiva e focada na rede, não no endpoint. Logo, não é a resposta correta.
- *Proxy:* Proxy é um servidor intermediário que atua entre usuários e a internet, podendo filtrar conteúdo e cachear páginas. Não é uma solução de segurança de endpoint com capacidade de detecção e resposta a ameaças. Portanto, não corresponde ao enunciado.

2) A — Implementar a solução correspondente: EDR: vê o comportamento e RESPONDE (isola o host)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Endpoint Security): EDR: vê o comportamento e RESPONDE (isola o host).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

3) C — Implementar a solução correspondente: Posture assessment: o 'exame de saúde' antes de conectar à rede....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Endpoint Security): Posture assessment: o 'exame de saúde' antes de conectar à rede.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) B — Implementar a solução correspondente: 'detects malicious behavior on endpoint and can isolate'=EDR....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Endpoint Security): 'detects malicious behavior on endpoint and can isolate'=EDR.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) B — Implementar a solução correspondente: 'endpoint detectou comportamento anômalo e isolou a máquina'=EDR.....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Endpoint Security): 'endpoint detectou comportamento anômalo e isolou a máquina'=EDR..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) C — Implementar a solução correspondente: EDR: vê o comportamento e RESPONDE (isola o host)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Endpoint Security): EDR: vê o comportamento e RESPONDE (isola o host).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam

ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) D — Implementar a solução correspondente: Posture assessment: o 'exame de saúde' antes de conectar à rede....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Endpoint Security): Posture assessment: o 'exame de saúde' antes de conectar à rede.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) A — Implementar a solução correspondente: 'detects malicious behavior on endpoint and can isolate'=EDR....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Endpoint Security): 'detects malicious behavior on endpoint and can isolate'=EDR.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) D — Implementar a solução correspondente: 'endpoint detectou comportamento anômalo e isolou a máquina'=EDR.....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Endpoint Security): 'endpoint detectou comportamento anômalo e isolou a máquina'=EDR..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) C — Implementar a solução correspondente: EDR: vê o comportamento e RESPONDE (isola o host)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Endpoint Security): EDR: vê o comportamento e RESPONDE (isola o host).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.